

3 min read · 1 day ago



Princeroy

Follow



Listen



Share

... More



Bug Bounty Methodology: A Practical Guide for PRO & Hunters 2025 to 2027 💰



Bug bounty hunting is like treasure hunting on the internet 🌐. Companies launch bounty programs so security researchers (like you!) can test their applications, find security loopholes, and get rewarded. If you're just starting out or want to make your methodology more solid, this guide will help you structure your workflow like a pro.

1. 🎯 Getting Started with Bug Bounties

Bug bounty programs reward ethical hackers for finding vulnerabilities. Some popular platforms you can join:

HackerOne

Bugcrowd

Intigriti

YesWeHack

Synack

💡 Pro Tip: Always read the program scope and rules of engagement carefully before testing.

2. 🌸 Setting Up Your Hacker Environment

A clean and well-structured environment saves time and keeps recon organized.

🔧 Essential Tools:

Burp Suite → Request interception & testing

ZAP Proxy → Alternative to Burp

Subfinder / Amass → Subdomain discovery

httpx → Probing live hosts

ffuf / dirsearch → Directory & file fuzzing

Arjun → Parameter discovery

Nuclei → Vulnerability templates

📁 Suggested Folder Structure:

```
~/bugbounty/  
├── target.com/  
│   ├── recon/  
│   ├── notes.md  
│   └── screenshots/
```

Always use a VPN or VPS to avoid exposing your real IP.

3. 🎯 Choosing the Right Target

Don't jump randomly. Pick targets smartly:

High payouts + low reports = better chance

Stick to technologies you understand at first

Prefer active, responsive programs

Platforms often allow you to filter programs (e.g., web apps only, API programs, mobile apps, etc.).

4. 🔍 Reconnaissance – Information is Power

Recon = collecting every detail about your target. More info = more bugs.

🌐 Subdomain Enumeration:

```
subfinder -d target.com -o subs.txt
```

```
amass enum -passive -d target.com -o amass.txt
```

📷 Visual Recon (Screenshots):

Using httpx + Aquatone:

```
cat subs.txt | httpx -status-code -title -tech-detect -o live.txt
```

```
cat live.txt | cut -d ' ' -f1 | aquatone
```

Screenshots help you spot login pages, admin panels, or misconfigured services visually.

🗂️ Asset Discovery:

Chaos Project → Massive dataset of bounty targets

crt.sh → Certificate logs = hidden subdomains

💡 Hackers' Tip: Combine chaos data with httpx to quickly find live assets.

5. 🌐 Endpoint & Directory Discovery

Many bugs hide in forgotten endpoints.

```
ffuf -u https://target.com/FUZZ -w /SecLists/wordlist.txt -t 50
```

Try wordlists from SecLists.

6. 🍷 Parameter Discovery = Juicy Bugs

Parameters often lead to:

XSS

SQL Injection

IDOR

SSRF

Open Redirects

Tool: Arjun

```
python3 arjun.py -u https://target.com/page --get
```

Track parameters in a sheet or Notion so you don't repeat work.

7. 🕵 Manual Testing Techniques

Automation is great, but manual testing = high-impact findings.

Check for:

Logic flaws (e.g., skipping payment)

Race conditions (sending requests fast)

Broken access control / IDOR

Weak session management

👉 Example: Try reusing a password reset token or changing user_id=123 to 124.

8. 📄 Reporting the Bug Like a Pro

Your report decides your payout. Keep it:

Clear → Simple language, no extra jargon

Reproducible → Step-by-step instructions

Impactful → Why this matters for the company

Evidence-based → Screenshots, curl requests, or PoC scripts

Report Format:

1. Title

2. Summary

3. Steps to Reproduce

4. Impact & Risk

5. Proof of Concept (PoC)

6. Suggested Fix

9. 🔄 After Reporting – Keep Learning

Track accepted & rejected bugs

Maintain a bug journal

Revisit old notes (sometimes a “low” finding later becomes “critical”)

Consistency matters more than luck.

🔧 Quick Tool Reference:

Tool Purpose

Burp Suite Proxy & testing

Nuclei Automated vuln scan

Subfinder Subdomain discovery

httpx Host probing

ffuf Fuzzing directories

Arjun Parameter discovery

Aquatone Screenshots

Dalfox XSS detection

🚀 Final Thoughts

Bug bounty hunting isn't just about tools — it's about curiosity, persistence, and creativity. Start small, take good notes, and keep experimenting. With a solid methodology, you'll turn small wins into big payouts.

Happy hunting, hacker! 🕵️💻💰

Bug Bounty

Ethical Hacking

Sql Injection

Xss Attack

Rewards



Follow

Written by Princeroy

1 follower · 1 following

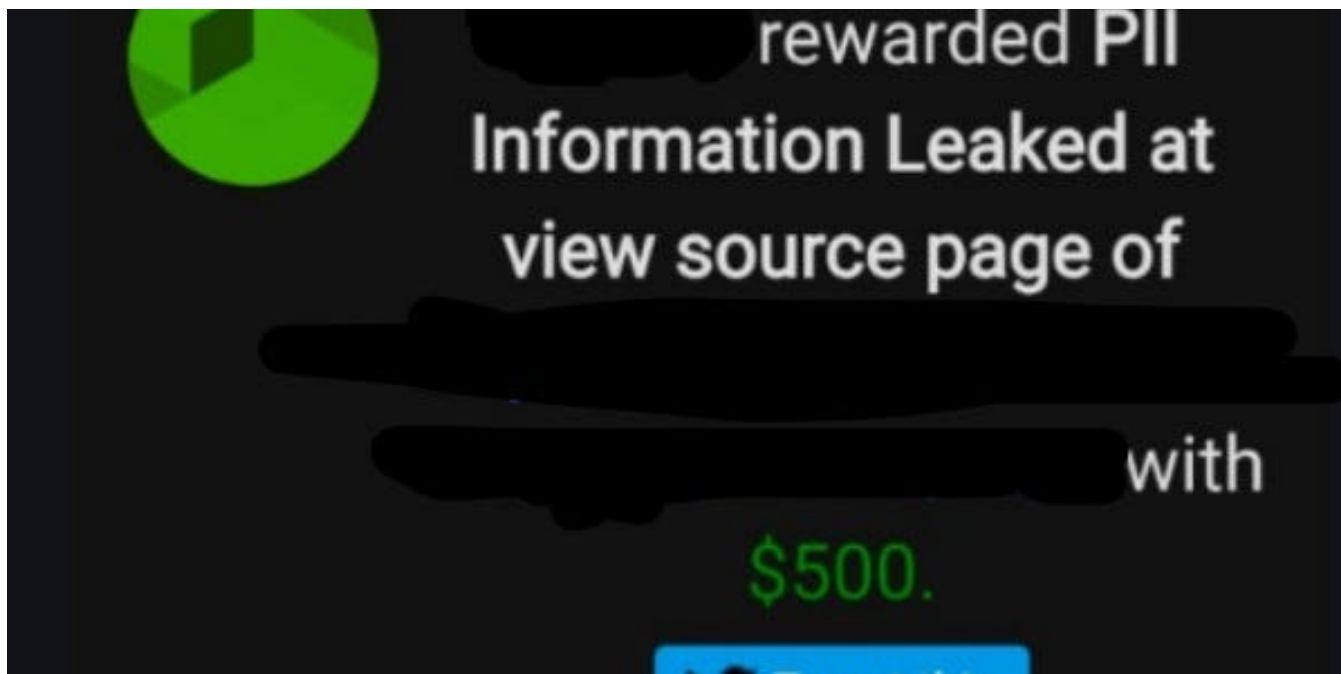
No responses yet



Sumanthsrianand

What are your thoughts?

Recommended from Medium



🧐 In InfoSec Write-ups by TSxNINJA

How I Clinched \$500 Within Minutes !!

Even the Developers said YOU_ARE_LUCKYYY!!!

🌟 Jul 29 🤝 234 💬 5





 In OSINT Team by Monika sharma

\$1000 Bounty: From 403 to Source Code

A \$1,000 Bug Bounty for Discovering Open Directory Listings in Hidden Java Web Paths

★ Jul 20 🤝 61 💬 5



 TEAM DH49

IDOR via Websockets allow me to takeover any users account

Hi everyone I hope you all are doing great and scoring lots of bounties. I am TeamDh49 Admin I am from India and I do bug bounty full time...

3d ago

👏 61

💬 2



hackerone

██████ rewarded you with a bounty of **\$2,500** for IDOR when ██████ If you're as excited as we are, [go ahead and tweet about it!](#)

Beyond the bounty amount, do not disclose any weakness information without the

Open in app ↗

≡ Medium



👤 L4zyhacker

IDOR vulnerability gives me 2500\$

Hi guy, I am a bug hunter, have 3–4 years of experience

Aug 9

👏 20

💬 1



```
! BANG BANG !
=====
----- Internet Explorer passwords -----
Password found !!!
Username: zapata@yahoo.com
Password: Zapata_Uive!
Site: https://www.facebook.com/

----- Firefox passwords -----
Password found !!!
Website: https://accounts.google.com
Username: zapata@gmail.com
Password: LaLuchaSigue!

Password found !!!
Website: https://www.facebook.com
Username: che.guevara@gmail.com
Password: hasta_siempre!
```

👤 Very Lazy Tech 🐛

Stealing All Saved Passwords From Any PC: The LaZagne Method (Ethical Guide)

🌟 Free Link in the first comment

🌟 Aug 10 🖱 95 💬 1



In MeetCyber by Narendar Battula (nArEn)



Prompt Engineering Toolkit (2025 Edition)

“JavaScript files don’t just power the frontend—they spill secrets, expose APIs, and open attack paths. You just need to ask the right...”

🌟 5d ago



See more recommendations